

Law & Data — Collection of Open Questions

Note to the reader. This document collects open questions from previous academic years' exams. Unlike the closed-question companion, no official answer keys were provided; the answers here represent a personal reconstruction, developed with the assistance of an AI model (Claude Opus 4.8). Where an official grading guideline existed — specifying the points or concepts that a correct answer should cover — it is reproduced under a *Should include* heading below the relevant question. Treat these answers as a study aid and a starting point, not as authoritative model solutions.

1. Please identify and illustrate three legal problems posed by social credit systems in no more than 150 words. (Summary: §12.3)

Social credit systems raise three main legal problems. First, **privacy and data protection**: they involve mass collection, aggregation, and continuous monitoring of personal data, often without genuine consent or transparency, violating GDPR principles and Article 8 CFR. Second, **discrimination and equality**: opaque, automated scoring produces unjustified differential treatment based on behaviour or personal characteristics, risking social exclusion without adequate redress. Third, **due process and rule of law**: sanctions and restrictions are imposed without a clear legal basis, procedural safeguards, or effective remedies, producing chilling effects on freedom of expression and association. Under EU law, the AI Act (Regulation 2024/1689, Art. 5) classifies government social scoring as an unacceptable-risk practice and prohibits it outright.

2. Please explain the main principles for personal data processing in no more than 200 words.
(Summary: §8.3)

Article 5 GDPR sets out seven principles governing personal data processing. (1) **Lawfulness, fairness, and transparency**: processing must rest on a valid legal basis (Art. 6), be fair to data subjects, and provide clear information on purposes, the controller's identity, and data subjects' rights. (2) **Purpose limitation**: data must be collected for specified, explicit, and legitimate purposes and not processed in incompatible ways. (3) **Data minimisation**: only data adequate, relevant, and limited to what is necessary may be processed. (4) **Accuracy**: data must be kept correct and up to date; inaccurate data must be rectified or erased. (5) **Storage limitation**: data must be kept identifiable no longer than necessary; Art. 17 obliges erasure once the purpose lapses. (6) **Integrity and confidentiality**: appropriate technical and organisational measures (TOMs) must protect data from unauthorised access or destruction. (7) **Accountability**: controllers must be able to demonstrate compliance with all these principles — a principle rooted in Convention 108.

3. Please illustrate in no more than 100 words the EU personal data protection package adopted since 2016. (Summary: §10.2)

The EU personal data protection package adopted since 2016 comprises four instruments forming a coherent system. The **GDPR** (Regulation 2016/679) is the centrepiece, establishing a comprehensive framework for personal data processing in and outside the EU. The **Law Enforcement Directive** (2016/680) governs data protection in the police and criminal justice sector, replacing Framework Decision 2008/977/JHA. The **ePrivacy Directive** (2002/58/EC) remains in force, regulating personal data in the electronic communications sector. **Regulation 2018/1725** extends equivalent standards to processing by EU institutions, bodies, and agencies.

4. Please describe in no more than 250 words the 2020 European Data Strategy conceived by the European Union. (Summary: §10, §10.1, §10.3)

In 2020, the EU adopted a European Data Strategy as part of the Commission's **Digital Decade (2020–2030)**, aiming to make the EU a leader in the data economy. The **GDPR paved the way** by ensuring the free flow of personal data under harmonised rules, establishing trust and a baseline for data policy.

The Strategy pursues **three aims**: (a) the **free flow of personal data** — ensuring protection, privacy, portability, and cross-border flow; (b) the **free flow of non-personal data** — overcoming data-localisation restrictions; and (c) a **single market for data** — enabling data sharing across sectors and infrastructure.

To achieve these aims the EU adopted a **legislative package**: the **Data Governance Act** (DGA, 2022) establishes a framework for trustworthy data sharing and reuse (public-sector data, intermediaries, altruism); the **Digital Services Act** (DSA, 2022) creates a safer digital space and imposes platform accountability and transparency; the **Digital Markets Act** (DMA, 2022) ensures fair competition and curbs the market power of gatekeepers; the **AI Act** (Regulation 2024/1689) establishes a risk-based harmonised framework for artificial intelligence; and the **Data Act** (2023) guarantees fair access to and use of data generated by connected products and services across all sectors.

Should include:

- (a) The GDPR that paved the way to the 2020 European Data Strategy.
- (b) Aims of the EU Data Strategy: free flow of personal data, free flow of non-personal data, single market for data.
- (c) EU Data Strategy Package: Data Governance Act, Digital Services Act, Digital Markets Act, Artificial Intelligence Act, Data Act (a summarized description of their contents).

5. Please explain the so-called “Barbra Streisand Effect” in no more than 100 words. (Summary: §12.4)

In 2003, Barbra Streisand sued to have aerial photographs of her Malibu home removed from a public website. Before the lawsuit the images had been downloaded only a handful of times; after the complaint was filed, more than 400,000 people viewed them within a month. The **Streisand Effect** names this paradox: attempting to suppress information through legal action can backfire and dramatically increase its dissemination. Two takeaways follow: first, the legal protection of privacy can sometimes consist in *not* seeking legal protection; second, the **legal vindication** of privacy — winning a right in court — may differ from, and even oppose, its **social enjoyment** — actually keeping information private.

Should include:

- (a) A brief summary of the facts of the case.
- (b) Description of the Effect: the protection of privacy through legal means can backfire and worsen the situation of the individual.
- (c) Takeaways:
 - the legal protection of privacy can consist in avoiding seeking legal protection;
 - the legal vindication of privacy is different—and sometimes opposite—from the social enjoyment of privacy.

6. Please describe any legal provision included in EU primary law sources setting out the right to personal data protection in max 250 words. (Summary: §7.1)

TEU: Article 2 lists human dignity, freedom, democracy, and the rule of law among the Union’s foundational values; Article 3 sets the objectives for pursuing them, including the protection of human rights — the constitutional backdrop for data protection as a fundamental right.

TFEU: Article 16(1) expressly states that everyone has the right to the protection of personal data and provides the legal basis for EU data-protection legislation (Parliament + Council, ordinary legislative procedure). Article 39 TEU is a *lex specialis* for data protection in the Common Foreign and Security Policy (CFSP): rules are adopted by the Council alone and prevail over Art. 16 in that domain.

Charter of Fundamental Rights (CFR): proclaimed in 2000 and legally binding since the Treaty of Lisbon (2009), it has the same legal status as the founding treaties. Article 7 CFR protects the right to private and family life — a negative right against interference. Article 8 CFR establishes an **autonomous** right to personal data protection: everyone has the right to have their data processed fairly, for specified purposes, on consent or another legitimate basis, with rights of access and rectification, and subject to an independent supervisory authority. Article 8 governs the *rules* of processing; Article 7 protects against *interference* with private life.

Article 52 CFR — the safeguard clause — provides that any limitation on Charter rights must be laid down by law, respect the essence of the right, pursue a legitimate general-interest objective, and be necessary and proportionate, enabling the balancing of conflicting fundamental rights.

Should include:

- (a) Personal data protection in the TEU, starting from the values of the EU as protected by article 2 TEU and the protection thereof set out in article 3 TEU.
- (b) Personal data protection as set forth by article 16 TFEU.
- (c) The fundamental right to data protection in the Charter of Fundamental Rights (article 8 CFR) and possible reference to article 7 CFR on the right to privacy (and their differences).
- (d) Possible limitations of fundamental rights and, specifically, of the right to data protection in light of the safeguard clause (article 52 CFR)—the balancing of conflicting rights.

7. Please describe the structure of the “proportionality scrutiny” in no more than 200 words.
(Summary: §12.2)

Proportionality scrutiny is a structured, sequential judicial test used to assess whether a measure restricting fundamental rights or competing interests is lawful. Failing any step renders the measure unlawful.

- (a) **Legitimate goal:** does the measure pursue a legitimate general-interest aim? A measure serving only private or arbitrary ends fails at the outset.
- (b) **Rational connection** (some courts omit this step): is the measure concretely and rationally suited to achieving the stated goal?
- (c) **Necessity — least restrictive means:** is there no equally effective but less restrictive alternative? If a less intrusive means achieves the same aim, the measure is disproportionate.
- (d) **Proportionality *stricto sensu*:** do the benefits outweigh the harm caused to the affected rights and interests? Even a necessary measure may be struck down if its costs clearly exceed its benefits.

This test was applied in *Digital Rights Ireland* (C-293/12), where the Data Retention Directive failed step 3 (blanket, untargeted mass retention was not the least restrictive means) and was struck down.

Should include:

- (a) Does the measure under scrutiny pursue a legitimate goal?
- (b) Is the measure concretely connected with the purported goal (the “rational connection” step—some courts omit it)?
- (c) Is the measure necessary to pursue that goal? (the “least restrictive means” step)
- (d) Are the benefits more than the sacrifices that the measure causes to the interests and rights that are involved?

8. Please explain what ‘personal data’ means according to the EU personal data protection legislation and the difference with sensitive personal data in no more than 200 words. (Summary: §8.2, §8.4)

Personal data (Art. 4(1) GDPR) is any information relating to an identified or identifiable natural person (the data subject), whether directly or indirectly — by name, ID number, location data, online identifier, or factors specific to that person’s physical, physiological, genetic, mental, economic, cultural, or social identity.

Sensitive data — formally the “special categories” (Art. 9 GDPR) — are a subset revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade-union membership, genetic or biometric data (for unique identification), health data, or data concerning sex life or sexual orientation. This distinction originates in Convention 108 (1981) and the OECD Guidelines (1980).

Differences in processing: personal data may be processed on any of the six lawful bases in Art. 6 (consent, contract, legal obligation, vital interests, public-interest task, legitimate interests). Sensitive data processing is **prohibited in principle**; exceptions are exhaustive: explicit consent, employment or social-security law, vital interests where the subject cannot consent, legal claims, substantial public interest, public health, non-profit activities, or research. The stricter regime reflects the higher risk of discrimination and harm that these categories carry.

Should include:

- (a) Definition of personal data according to article 4(1) of the GDPR.
- (b) Definition of sensitive data, even involving article 9 GDPR.
- (c) Differences in the processing of personal data and sensitive personal data.
- (d) Lawful reasons for processing personal data and sensitive personal data with or without data subjects’ consent.
- (e) Possible references to the origins of the definition of personal data and sensitive personal data (Convention 108, OECD Guidelines).

9. Please describe which are the main rights recognized to a data subject by the GDPR in max 250 words. (Summary: §8.7, Table A.1)

The GDPR recognises the following rights for data subjects:

- (a) **Right of access** (Art. 15): the right to obtain confirmation that personal data are being processed and to receive a copy.
- (b) **Right to rectification** (Art. 16): the right to have inaccurate or incomplete data corrected.
- (c) **Right to erasure — right to be forgotten** (Art. 17): the right to request deletion of data no longer necessary, or where consent is withdrawn; established in *Google Spain* (C-131/12, 2014).
- (d) **Right to restriction of processing** (Art. 18): the right to limit processing in certain circumstances (e.g., while accuracy is contested).
- (e) **Right to data portability** (Art. 20): the right to receive personal data in a portable format and transmit it to another controller.
- (f) **Right to object** (Art. 21): the right to object to processing based on legitimate interests or for direct marketing.
- (g) **Right not to be subject to solely automated decisions** (Art. 22): the right not to be bound by decisions based solely on automated processing that produce significant legal or similarly significant effects.
- (h) **Right to lodge a complaint** (Art. 77): the right to complain to the competent national supervisory authority.
- (i) **Right to judicial redress** (Arts. 78–79): the right to seek legal redress before courts against a supervisory authority or a controller/processor.

Should include:

- (a) Right to access.
- (b) Right to data rectification.
- (c) Right to data erasure—right to be forgotten.
- (d) Right to processing restriction.
- (e) Right to data portability.
- (f) Right to limit the processing.
- (g) Right to object to data processing.
- (h) Right to lodge a complaint before the NSA.
- (i) Right to seek legal redress before Courts.

10. Why is the notion of synthetic data relevant in the field of privacy protection? How would you define synthetic data? (Summary: §12.5)
-

Synthetic data is artificially generated data that reproduces the statistical properties of real datasets without referring to identifiable individuals. The definition comes from academic literature, as no EU legislation specifically governs it yet.

Synthetic data is relevant to privacy protection for several reasons. First, it offers **robust anonymisation**: since it does not derive directly from real records, it significantly reduces re-identification risk. Second, it enables **data sharing and collaboration** — organisations can share synthetic datasets without exposing real personal data, facilitating research and development. Third, it helps overcome **data scarcity**, providing a reliable alternative for training machine-learning models when real data is limited or sensitive.

Because synthetic data does not relate to identifiable individuals, it generally **falls outside the GDPR's** scope. It differs from anonymised data, which loses detail and is therefore less useful for training algorithms, and from pseudonymised data, which remains personal data.

11. Please describe how the right to privacy evolved into the right to personal data protection in no more than 150 words. (Summary: §6.4)

Privacy was originally conceived as a **negative, liberty-based right**: protection against intrusion into private and family life (UDHR Art. 12, 1948; ECHR Art. 8, 1950; ICCPR, 1966). This proved insufficient in the era of large-scale data processing, which enabled systematic collection, storage, and use of personal information beyond the reach of a mere anti-interference right.

The right to **personal data protection** emerged to regulate this new reality. International instruments codified it: the OECD Privacy Guidelines (1980) set the first universal principles for data processing; Convention 108 (CoE, 1981) was the first binding international instrument on data protection. In the EU, the right became an **autonomous fundamental right** under Art. 8 CFR (binding since 2009) and Art. 16 TFEU, shifting from a liberty-based to a **dignity-based** approach that gives individuals control over their data and protects them from surveillance, profiling, and manipulation.

12. Please describe a Data Protection Impact Assessment and its aims in no more than 150 words. (Summary: §8.6)

A **Data Protection Impact Assessment (DPIA)** is a preventive procedural tool under Art. 35 GDPR. It is **mandatory only when** processing is likely to cause a high risk to the rights and freedoms of natural persons — for example, large-scale processing of sensitive data, systematic monitoring of public spaces, or solely automated decision-making with significant effects.

A DPIA must contain: (1) a **systematic description** of the envisaged processing operations and their purposes; (2) a **necessity and proportionality analysis** — assessing whether processing is necessary and proportionate to the aims pursued; (3) a **risk assessment** identifying risks to the rights and freedoms of data subjects; and (4) **mitigation measures** — technical and organisational measures to address those risks.

The DPIA embodies the GDPR's **risk-based approach**: controllers must proactively identify and address privacy risks before processing begins, rather than reacting after harm occurs.

13. Please describe in no more than 150 words the difference between EU regulations and directives. (Summary: §5.3)

EU secondary law (Art. 288 TFEU) distinguishes two main types of binding legislative act.

A **regulation** is binding in its entirety and **directly applicable** in all member states: it requires no transposition into national law and becomes immediately enforceable, producing uniform rules across the EU.

A **directive** is binding **as to the result** to be achieved but leaves member states the choice of form and method. States must transpose it before the implementation deadline. After that deadline, clear, precise, and unconditional provisions acquire **direct effect** — individuals may rely on them before national courts even without transposition.

Other secondary acts include decisions (binding on those addressed), and recommendations and opinions (soft law, non-binding).

14. Please describe the main subjects involved in personal data processing activities and their rights and obligations according to the GDPR in no more than 200 words. (Summary: §8.7, Table A.2)

The GDPR identifies five main subjects.

Data subject: the identified or identifiable natural person to whom data relate; holds enforceable rights (access, rectification, erasure, portability, restriction, objection, complaint, judicial redress).

Controller: determines the **purposes and means** of processing; bears primary accountability; must adopt TOMs, keep records, cooperate with subjects and authorities, and designate a DPO where required. Where two or more entities jointly determine purposes and means they are **joint controllers** with equivalent liability.

Processor: processes data on behalf of and on the instructions of the controller (Art. 28 contract required); may appoint sub-processors with authorisation; implements TOMs.

Data Protection Officer (DPO): mandatory for public authorities, entities conducting large-scale systematic monitoring, or large-scale processing of special categories; advises on compliance and acts as a bridge to supervisory authorities.

Supervisory authority: an independent national body (Art. 51 GDPR; basis: Art. 8 CFR); handles complaints, monitors GDPR application, and cooperates via the European Data Protection Board (EDPB).

15. Please describe in no more than 150 words the legal status of EU regulations. (Summary: §5.3)

A regulation is an act of EU secondary law adopted under Art. 288 TFEU. It is **binding in its entirety** — unlike a directive, a regulation leaves no discretion to member states as to its content. It is **directly applicable** in all member states: once it enters into force, it is immediately enforceable without any need for national transposition, ensuring uniform and simultaneous application of the same rules across all member states.

Under the principle of **primacy** of EU law (established in *Costa v. ENEL*, 6/64, 1964), national law incompatible with a regulation must be set aside. Regulations occupy the secondary law level in the EU hierarchy of sources — below primary law (TEU, TFEU, Charter, general principles) and international agreements.

16. Please describe the differences of processing activities involving personal data and sensitive personal data in no more than 150 words. (Summary: §8.2, §8.4)

Personal data (Art. 4(1) GDPR) may be processed on any of the **six lawful bases** in Art. 6: consent; performance of a contract; compliance with a legal obligation; protection of vital interests; performance of a public-interest task; or the legitimate interests of the controller or a third party (provided they do not override the data subject's rights).

Sensitive data — the special categories in Art. 9 GDPR (racial/ethnic origin, political opinions, religious or philosophical beliefs, trade-union membership, genetic and biometric data, health data, sex life/sexual orientation) — is **prohibited from processing in principle**. It may be processed only where a specific exception applies: explicit consent; employment or social-security law; vital interests; legal claims; substantial public interest or public health; non-profit activities for members; or research.

The stricter regime reflects the higher risk of discrimination and harm. The distinction originates in Convention 108 (1981) and the OECD Guidelines (1980).

17. Please describe the evolution of [personal] data protection legislation in the EU legal system in no more than 12 lines. (Summary: §7 (table), §7.1, §5.1, §8, §10.2)

Data protection legislation in the EU evolved through three phases. **Directive 95/46/EC** (1995) established the first general framework with a **liability-based approach**: entities were bound only by national implementing law, and enforcement was reactive. Primary law simultaneously anchored data protection as a fundamental right: **Arts. 2 and 3 TEU** enshrine human rights among the Union's values and objectives; **Art. 16(1) TFEU** expressly guarantees the right to personal data protection and provides the legislative basis (Parliament + Council); **Art. 39 TEU** is a *lex specialis* for CFSP data rules (Council alone). The **Charter of Fundamental Rights** — proclaimed at Nice (2000) with **Art. 7** (private life) and **Art. 8** (personal data protection) — became binding with the Lisbon Treaty (2009). CJEU case-law reinforced these rights: *Digital Rights Ireland* (2014) struck down the Data Retention Directive for disproportionate mass surveillance; *Google Spain* (2014) established the right to be forgotten; *Schrems* (2015) invalidated the EU-US Safe Harbor for inadequate protection. The third phase is the shift to a **compliance-oriented approach**: **GDPR (Regulation 2016/679)** replaced Dir. 95/46/EC with a directly applicable instrument whose accountability principle (Art. 5(2)) requires proactive demonstration of compliance. The **EU Data Protection Package** (GDPR, Dir. 2016/680, ePrivacy Dir. 2002/58/EC, Reg. 2018/1725) built a coherent, comprehensive system.

Should include:

- (a) Directive 95/46/EC (liability approach).
- (b) Nice Charter, articles 7 and 8.
- (c) Articles 2 and 3 of the TEU.
- (d) Article 16 of the TFEU.
- (e) Article 39 of the TEU.
- (f) Charter of Fundamental Rights, articles 7 and 8.
- (g) Shift to a compliance approach → GDPR.
- (h) Data Protection Package.
- (i) Reference to CoE (i.e. case-law).
- (j) Possible references to other EU directives and regulations.

(References to Convention 108 and Convention 108+, as well as to the OECD Guidelines or to the UN Declaration of Human Rights or the ECHR were useful, but did not directly concern the European Union legal system, rather belonging to different legal systems—respectively, CoE and OECD.)

18. Please describe the development of EU secondary law (from directives to regulations) of personal data and the reasons underlying said development in no more than 15 lines. (Summary: §5.3, §8, §9.3, §10.2)

EU data protection legislation began with **Directive 95/46/EC**, which introduced the first general framework but required national transposition: each member state chose its own form and method, producing a **liability-based approach** where entities were bound only by national law and enforcement was reactive. The parallel **ePrivacy Directive 2002/58/EC** followed the same model for electronic communications. Fragmentation across member states undermined the single market and legal certainty.

To address this, the EU shifted to **regulations**. The **GDPR (Regulation 2016/679)**, applicable from May 2018, replaced Directive 95/46/EC with a directly applicable instrument binding entities across all member states without transposition. It introduced a **compliance-oriented approach**: its accountability principle (Art. 5(2)) requires controllers to proactively *demonstrate* compliance, operationalised through data protection by design/default (Art. 25), mandatory DPIAs (Art. 35), records of processing activities (Art. 30), and the DPO. **Regulation 2018/1725** extended equivalent standards to EU institutions. The contemporaneous **Directive 2016/680** (law enforcement) retained directive form where per-state flexibility was necessary. The broader **EU Data Protection Package** (GDPR, Dir. 2016/680, ePrivacy Directive, Reg. 2018/1725) built a coherent system. The reasons for the shift from directives to regulations are therefore twofold: (1) achieve **maximum harmonisation** and uniform rules eliminating single-market fragmentation; (2) move from reactive liability to proactive **compliance**.

Should include:

- (a) Directive 95/46.
- (b) GDPR 2016/679.
- (c) Regulation 2018/1725.
- (d) Directive 2016/680 (on prevention, investigation, detection, prosecution of criminal offences).
- (e) EU Data Protection Package.
- (f) Using directives shifted to the use of regulations to ensure a compliance-oriented approach.
- (g) More harmonization within the EU (reason for the shift from directives to regulations).